



Anti Money Laundering and Financial Crime Policy Manual

*Customer due diligence risk rating sanctions screening transaction monitoring
and enterprise risk assessment*

Version 1.0 | Effective 1 October 2026

Fictional UAE digital bank policy prepared as a professional portfolio example

Document control

This manual describes the minimum financial crime controls expected across Ashar Digital PJSC. It is written for employees, contractors and service providers who design products, onboard customers, process payments, investigate activity or provide independent assurance.

Ashar Digital PJSC is a fictional institution. The document is a portfolio simulation and is not evidence of a banking licence, board approval or legal advice. A real institution would tailor the controls to its licence, products, systems, risk appetite and supervisory directions.

Field	Controlled value
Document owner	Money Laundering Reporting Officer
Business owner	Financial Crime Compliance
Approval authority	Board Risk and Compliance Committee
Version	1.0
Effective date	1 October 2026
Next scheduled review	30 September 2027
Review cycle	At least annually and after a material trigger
Classification	Portfolio simulation
Regulatory scope assumed	UAE licensed digital bank supervised by the Central Bank of the UAE

Approval record

Role	Decision	Date	Name or signature
MLRO	Recommended	Illustrative	Not applicable
Chief Executive Officer	Endorsed	Illustrative	Not applicable
Board Risk and Compliance Committee	Approved	Illustrative	Not applicable

Change history

Version	Date	Change	Owner
1.0	1 October 2026	Initial portfolio edition	Financial Crime Compliance

Policy hierarchy

This manual sets the governing requirements. Detailed operating procedures, system rules, desk instructions and forms may add control steps, but they must not weaken this manual. If a local procedure conflicts with law, a regulatory direction or this manual, the stricter requirement applies until the MLRO resolves the conflict.

Contents

Section	Page
Document control	2
How to use this manual	3
Part 1 AML CFT and CPF governance	4
Part 2 KYC CDD and EDD procedure	9
Part 3 Customer risk rating methodology	15
Part 4 Sanctions and screening policy	20
Part 5 Transaction monitoring and STR framework	24
Part 6 Short enterprise wide risk assessment	29
Appendix A Decision and escalation authority	32
Appendix B CDD information and evidence	32
Appendix C Glossary	33
Appendix D Regulatory reference framework	33

How to use this manual

The manual combines policy and procedure in one place. Each part explains the rule, the responsible function and the evidence that must be retained. Staff should use it together with the relevant operating procedure and system guide.

- **Business and operations teams** should start with Parts 1 and 2, then use the escalation matrix in Appendix A.
- **Onboarding and periodic review teams** should use Parts 2 and 3 and the evidence guide in Appendix B.
- **Screening and transaction monitoring teams** should use Parts 4 and 5.
- **Senior management and assurance functions** should use Parts 1 and 6 to judge whether risks are understood, controlled and reported.

The words must and shall describe mandatory internal requirements. Should describes an expected practice that may be varied only with a documented reason. May describes an option. Where law or a regulator sets a shorter deadline or stricter standard, that requirement takes priority.

PART 1

AML CFT and CPF governance

How the Bank assigns responsibility manages risk and escalates concerns

1 Purpose and policy statement

Ashar Digital PJSC will not knowingly provide accounts, payment services or other facilities that support money laundering, terrorism financing, proliferation financing, sanctions evasion, fraud, corruption or another predicate offence. The Bank will identify and understand its financial crime risks, apply controls in proportion to those risks, and report suspicion to the UAE Financial Intelligence Unit when the legal threshold is met.

Commercial targets do not override financial crime controls. No employee may open an account, release a payment, suppress an alert or retain a relationship merely because the customer is valuable, senior or time-sensitive.

2 Scope and business assumptions

This manual applies to all directors, employees, contractors, branches, controlled subsidiaries and outsourced service providers acting for the Bank. The Bank remains responsible for an outsourced control even when a vendor performs the work.

For this portfolio example, the Bank is assumed to offer UAE retail current and savings accounts, debit cards, domestic and international payments, and accounts for small and medium-sized companies. Onboarding is mainly remote. The Bank does not offer cash branches, private banking, correspondent banking, trade finance, payable-through accounts, virtual asset services or anonymous products. A proposal to add any of these services requires a product risk assessment and approval before launch.

- No anonymous, fictitious, alias or numbered account may be opened.
- No account may be used until required identification, verification, screening and risk assessment are complete, except where law expressly permits delayed verification and the MLRO approves safeguards.
- The Bank will not enter or continue a relationship that falls outside its risk appetite or cannot be understood and monitored with reasonable confidence.

3 Regulatory framework

The Bank will maintain controls consistent with UAE law, applicable Central Bank rules and directions, the UAE targeted financial sanctions framework, UAE FIU reporting requirements and the FATF standards as implemented in the UAE. The Legal and Compliance functions will assess new or changed requirements and record the resulting policy, system and training actions.

The principal references used for this edition are listed in Appendix D. The list is a control aid, not a substitute for checking the current official text.

4 Risk based approach

A risk-based approach means the Bank spends more effort where the chance or impact of financial crime is higher. It does not mean that lower-risk customers receive no checks, or that higher-risk customers must always be rejected.

1. Identify risk in customers, ownership structures, countries, products, delivery channels and transaction behaviour.
2. Assess inherent risk before considering controls.
3. Apply controls that are suitable for the risk and test whether they work.
4. Decide the residual risk after controls and compare it with the Bank's risk appetite.

5. Monitor changes and reassess when new facts, products, typologies or regulatory requirements arise.

Simplified due diligence may be used only where law permits, the relationship presents demonstrably lower risk and the rationale is recorded. It must never be used when there is suspicion, a sanctions concern, doubt about identity or beneficial ownership, or another higher-risk indicator.

5 Governance and oversight

Body or role	Core responsibility	Evidence
Board	Sets financial crime risk appetite, approves this manual and holds senior management accountable.	Minutes, approvals and challenge recorded.
Board Risk and Compliance Committee	Reviews material exposure, breaches, overdue remediation, significant regulatory matters and the annual EWRA.	Quarterly packs and action logs.
Executive Management Committee	Provides staff, systems and funding; resolves cross-functional control issues; oversees remediation.	Monthly management information and decisions.
MLRO	Leads the AML/CFT/CPF programme, decides external suspicion reporting and has direct access to the Board.	MLRO reports, goAML records and advice.
Business heads	Own risk in their products and customers and make sure first-line controls operate.	Control attestations and issue logs.
Internal Audit	Provides independent assurance over governance, design and operating effectiveness.	Risk-based audits and tracked findings.

6 Three lines of defence

Line	Who sits here	What the line must do
First line	Business, customer onboarding, payments operations, customer service, product, technology and data owners.	Know the customer, operate controls, question unusual activity, keep complete evidence and escalate promptly. The first line owns the risk.
Second line	MLRO, Financial Crime Compliance, sanctions advisory and compliance monitoring.	Set standards, advise, challenge, approve defined higher-risk matters, monitor compliance, decide reporting and provide independent oversight.
Third line	Internal Audit.	Assess independently whether governance, risk assessment and controls are designed well and operate as intended. Report without interference.

A control does not move to the second line merely because it concerns AML. For example, collecting customer documents and reviewing ordinary transaction alerts may be first-line activities if Compliance retains independent oversight, challenge and decision rights. The organisation chart and role profiles must make the allocation clear.

7 MLRO responsibilities and independence

The Board will appoint a suitably senior and competent MLRO, subject to regulatory approval where required. The MLRO must have enough authority, staff, information and system access to perform the role and must be able to raise a matter directly with the Chief Executive Officer, Board Chair or Board Risk and Compliance Committee.

- Maintain this manual, related standards and the annual compliance plan.
- Oversee the EWRA and advise on financial crime risk appetite.
- Receive internal suspicious activity referrals and make the final STR or SAR filing decision.
- Ensure reports are submitted through goAML accurately, promptly and confidentially.
- Oversee sanctions compliance, including confirmed and potential match reporting.
- Approve or advise on higher-risk customers, PEPs, material overrides, exceptions and exits as set out in Appendix A.
- Provide regular, candid reporting to senior management and the Board, including weaknesses and overdue actions.
- Act as a principal contact for the CBUAE, UAE FIU and other competent authorities on AML/CFT/CPF matters.
- Ensure staff receive role-based training and that control owners understand regulatory changes.

The MLRO may delegate research, administration and quality checks, but not accountability for the programme or the final external reporting decision. A deputy MLRO will act under a written delegation during absence. Any conflict involving the MLRO must be referred to the Chief Compliance Officer or Board Risk and Compliance Committee Chair.

8 Escalation and reporting

Staff must escalate a concern as soon as they identify it. They should not wait for proof of a crime. The receiving team must acknowledge, triage and protect the information from unnecessary disclosure.

Event	Immediate action	Escalation
Suspected sanctions match	Stop onboarding or suspend the payment. Do not alert the customer.	Sanctions team and MLRO immediately.
Suspicious activity	Preserve records and submit an internal referral with the available facts.	Financial Crime Investigations without delay.
CDD cannot be completed	Do not open, expand or continue the relationship without an approved legal basis.	Onboarding manager and Financial Crime Compliance.
Control failure or missed screening	Contain the issue, identify affected customers or payments and preserve logs.	Control owner, MLRO, Operational Risk and Technology as relevant.
Regulator or law enforcement contact	Authenticate the request and restrict circulation.	MLRO and Legal immediately.
Possible tipping off or data leak	Stop further disclosure and secure the evidence.	MLRO, Legal and Information Security immediately.

The MLRO will decide whether a breach is material, whether the regulator must be informed, and whether customers, systems or products require restrictions. Material issues and overdue high-risk actions will be reported to the Board Risk and Compliance Committee.

9 Training and employee controls

All employees and relevant contractors must complete financial crime training when they join and at least annually thereafter. Staff may not perform a controlled role until the required training is complete.

- **Foundation training** covers customer due diligence, sanctions, red flags, internal escalation, confidentiality and tipping off.
- **Role-based training** covers the actual decisions made by onboarding, payments, investigations, product, technology, senior management and the Board.
- **Targeted refreshers** are required after a material incident, poor quality result, regulatory change or new typology.
- **Competence checks** use short tests, case studies, file reviews or observed practice rather than attendance alone.

Human Resources will screen candidates for relevant roles in line with law and the Bank's employment standards. Conflicts of interest, misconduct concerns and unexplained access to restricted case information must be escalated.

10 Compliance monitoring audit and recordkeeping

Financial Crime Compliance will maintain a risk-based monitoring plan. Reviews will test whether controls are performed on time, decisions are supported, data moves correctly between systems and management information reflects the underlying records.

Internal Audit will assess the AML/CFT/CPF programme independently at a frequency supported by risk. The scope should include governance, EWRA, CDD, screening, transaction monitoring, reporting, data, model governance, outsourcing, training and remediation. Audit must have unrestricted access to relevant records and staff.

The Bank will retain CDD, transaction, investigation, screening, reporting, training, audit and risk-assessment records for at least five years from the applicable legal trigger, or longer where a legal hold, regulatory direction or investigation requires it. Records must be retrievable promptly and must show who did what, when, using which information and why the decision was reasonable.

11 Breaches exceptions and policy review

A business deadline is not a valid policy exception. An exception may be considered only where it is lawful, time-limited, supported by compensating controls and approved under Appendix A. Sanctions obligations, STR confidentiality, identity requirements and prohibited relationships cannot be waived.

The MLRO will review this manual at least annually and after a material change in law, guidance, business strategy, products, customer base, geography, delivery channel, systems, typologies or the EWRA. Changes will be approved at the level appropriate to their significance.

PART 2

KYC CDD and EDD procedure

A practical procedure for individuals legal entities ownership PEPs funds reviews and exits

1 CDD principles

Customer due diligence is the process of knowing who the customer is, who ultimately owns or controls the relationship, why the account is needed, how it is expected to be used and whether the explanation is consistent with reliable evidence. CDD is not complete merely because documents have been collected.

- Identify and verify the customer using reliable, independent data or documents.
- Identify and verify beneficial owners and persons who control or act for the customer.
- Understand the purpose and intended nature of the relationship.
- Establish expected account activity and assess financial crime risk.
- Screen relevant parties and resolve matches before a decision.
- Keep the information current and monitor activity throughout the relationship.

2 When CDD is required

CDD must be completed before establishing a business relationship, carrying out a relevant occasional transaction, adding a material product or service, or acting where identity information is doubtful. Existing customers remain subject to CDD when a periodic review is due or a trigger occurs.

If the Bank suspects money laundering, terrorism financing, proliferation financing or another crime, staff must escalate the concern even if the amount is small or the transaction was only attempted.

3 Standard onboarding workflow

1. Capture the customer and product request and obtain consent required for verification and screening.
2. Verify identity and, for a legal entity, legal existence and authority to act.
3. Identify beneficial owners, controllers, authorised persons and connected parties.
4. Understand the purpose, expected activity, occupation or business, geography and funding.
5. Run sanctions, PEP and adverse-media screening and investigate potential matches.
6. Calculate the customer risk rating and apply EDD where required.
7. Obtain the required approval, record the rationale and activate only the approved products and limits.
8. Set periodic review frequency and monitoring parameters and store the complete CDD record.

4 Individuals

For an individual, the Bank must obtain enough information to distinguish the person from another person with a similar name and to understand the intended use of the account. Appendix B lists the minimum data and common evidence.

- Full legal name, any former or other names, date and place of birth, nationality and gender where lawfully collected.
- Government-issued identity details, expiry date, residential address, contact details and tax residence.
- Occupation or employment, employer or business, expected income, purpose of account and expected activity.
- Source of initial funding and, where required, source of funds and source of wealth.
- Whether the person acts for another individual, legal person or arrangement.

Remote verification must use controls suitable for the impersonation and document-fraud risk. These may include document authenticity checks, liveness or biometric comparison, trusted digital identity, device and network signals, one-time passcodes and confirmation of a bank account held in the same name. Failed or

inconsistent checks require manual review; repeated failures may require rejection and an internal suspicious activity referral.

5 Legal entities and legal arrangements

The Bank must understand both the legal customer and the natural persons behind it. A trade licence or certificate of incorporation alone does not explain ownership, control, business purpose or expected account activity.

- Legal name, trading name, legal form, registration number, date and place of incorporation, registered and operating addresses.
- Constitutional documents, current licence, nature of business, countries of operation, tax residence and expected turnover.
- Directors, partners, trustees, authorised signatories and persons authorised to act, together with their authority.
- Ownership and control structure through each intermediate entity to the natural persons who ultimately own or control the customer.
- Purpose of the account, expected counterparties, payment corridors, transaction values and funding sources.
- For trusts and similar arrangements, the settlor, trustee, protector if any, beneficiaries or class of beneficiaries, and any other person exercising ultimate effective control.

The onboarding analyst must compare information across reliable registries, constitutional documents, licences, audited or management accounts, the customer's website and independent sources. Material inconsistencies must be resolved, not merely noted.

6 Beneficial ownership

A beneficial owner is always a natural person. The Bank will trace ownership and control through the full chain and identify each natural person who owns or controls 25 percent or more, individually or jointly. Ownership must be aggregated where holdings appear coordinated or are held through related vehicles.

1. Identify natural persons who meet the ownership threshold.
2. If ownership does not identify the true controller, identify the natural person who controls the entity through voting rights, appointment rights, agreements, influence or another means.
3. If no natural person can be identified after reasonable measures, record that work and identify the senior managing official as the fallback. The fallback does not remove the need to understand the ownership chain.
4. Verify beneficial owners on a risk-sensitive basis and screen them before approval and on an ongoing basis.

Where the structure is unusually complex, involves nominees, bearer instruments, trusts, private foundations, multiple layers with no clear commercial purpose or jurisdictions with weak transparency, EDD is required. The Bank may seek persons below 25 percent where this is necessary to identify effective control or manage sanctions and financial crime risk.

7 Politically exposed persons

A politically exposed person is someone entrusted with a prominent public function in the UAE, another country or an international organisation. Relevant family members and close associates are treated as related customers. PEP status is a risk factor, not an accusation of wrongdoing.

The Bank will use screening and customer information to identify PEPs at onboarding and during the relationship. For a foreign PEP and related customer, and for any domestic or international-organisation PEP assessed as higher risk, the Bank will:

- obtain senior management approval before opening or continuing the relationship;
- take reasonable measures to establish and corroborate source of funds and source of wealth;
- apply enhanced ongoing monitoring and more frequent review; and
- record why the relationship is within risk appetite and which controls apply.

A former PEP is not automatically declassified after a fixed period. The Bank will consider the role held, seniority, influence retained, access to public funds, links to current officials, country context and time since leaving office. Enhanced measures continue while a material PEP risk remains.

8 Source of funds and source of wealth

Source of funds explains where the money used in a particular transaction or relationship came from. Source of wealth explains how the customer accumulated their total wealth. A customer's statement may explain the story, but higher-risk cases require reasonable corroboration.

Situation	Expected evidence examples	What the reviewer checks
Salary or bonus	Payslips, employment letter, account statements, tax records.	Employer, amount, timing and consistency with role.
Business income	Financial statements, invoices, contracts, tax filings, business bank statements.	Trading activity, counterparties, margins and cash flow.
Sale of property or company	Sale agreement, title record, completion statement, receipt into an account.	Ownership, buyer, value and flow of proceeds.
Inheritance or gift	Probate, will, gift letter, donor identity and donor source.	Relationship, legitimacy, capacity and transfer trail.
Investment returns	Broker statement, portfolio records, dividend or redemption documents.	Original capital, investment history and payment route.
Loan	Executed agreement, lender identity, purpose, terms and transfer evidence.	Whether the loan is genuine and the lender can provide the funds.

Evidence should form a coherent trail. A bank statement showing a credit proves receipt, not the economic origin of the money. Where the customer cannot or will not provide reasonable evidence, the Bank will restrict or decline the activity and consider whether an internal referral is required.

9 Enhanced due diligence

EDD adds checks suited to the identified risk. It is not a standard bundle applied without thought. The analyst must explain the risk, the additional information obtained, how it was verified and why the remaining risk is acceptable.

- Obtain additional identity, ownership, business and financial information from independent sources.
- Establish source of funds and source of wealth in greater depth.
- Understand major counterparties, customer base, payment corridors and the reason for complex structures.
- Conduct focused adverse-media and open-source research in relevant languages.
- Obtain a compliance opinion and senior management approval where required.
- Set lower limits, restrict products, require first payment from an account in the same name or apply other proportionate controls.
- Review more often and apply enhanced transaction monitoring.

10 Screening during CDD

Before approval, the Bank will screen the customer, beneficial owners, controllers, directors, authorised persons, trustees, beneficiaries where identified, and other relevant connected parties. Sanctions matches are handled under Part 4. PEP and adverse-media results are assessed for risk and EDD; they are not treated as sanctions designations.

11 Periodic and trigger based reviews

Risk class	Maximum review cycle	Expected depth
Low	36 months	Confirm core data, screening, purpose and observed activity.
Standard	24 months	Refresh full profile and compare activity with expectations.
High	12 months	Full EDD refresh, SoF or SoW where relevant, senior approval.
Very high approved by exception	6 months	Full review of the exception, restrictions and continued rationale.

A trigger-based review must begin promptly when information suggests that the current profile may no longer be reliable. Examples include:

- a material change in ownership, control, directors, legal form, business activity, address or tax residence;
- a new PEP, sanctions, enforcement or serious adverse-media result;
- activity that is materially different from the expected profile;
- a request for a higher-risk product, corridor, limit or delivery channel;
- expired or doubtful identity documents, returned communications or suspected impersonation;
- an STR or SAR filing, law-enforcement request, material fraud concern or repeated monitoring alerts;
- a change in country risk, the Bank's risk appetite, law or regulatory expectation.

The Bank will not wait for the next periodic review when a trigger occurs. Material high-risk triggers must be triaged within five business days and managed sooner if sanctions, suspicion or customer harm is possible.

12 Rejection restriction and exit

The Bank will reject an application or exit a relationship when it is unlawful, outside risk appetite, based on false or materially incomplete information, cannot be understood with reasonable confidence, or cannot be monitored effectively. It may also restrict a product or transaction while a review is completed.

1. Record the facts, risk rationale, approvals and any legal or regulatory restriction.
2. Consider whether the circumstances require an internal referral, STR or SAR, sanctions report or regulator notification.
3. Plan the timing and method of communication without revealing an investigation or report.
4. Protect funds subject to a freeze, court order, law-enforcement instruction or other restriction. Do not close or return funds in a way that breaches the restriction.
5. Complete operational closure, remove access, settle lawful balances, retain records and update internal watchlists where justified.

A customer must not be told that an STR or SAR has been considered or filed. Communications should use a neutral and truthful explanation approved for the situation. The MLRO and Legal must be consulted where an exit could prejudice an investigation or create tipping-off risk.

PART 3

Customer risk rating methodology

A transparent model using customer geography product channel and behaviour

1 Purpose and model design

The customer risk rating helps the Bank decide the level of due diligence, approval, review and monitoring required. It supports judgement; it does not replace it. A rating must be traceable to current customer data and must respond when relevant facts change.

The model scores five risk dimensions from 1 to 5 and applies a documented weighting. Scores are assigned at onboarding and recalculated during reviews and after material triggers. The transaction-behaviour score becomes fully operative after activity is available.

2 Weightings

Risk dimension	Weight	Reason for weighting
Customer and ownership	35%	Identity, occupation, business, legal form, ownership and PEP or adverse information are central to risk.
Geography	20%	Residence, incorporation, operations and payment exposure affect predicate crime, sanctions and transparency risk.
Product and service	15%	Products differ in speed, value, anonymity, international reach and ability to move third-party funds.
Delivery channel	10%	Remote onboarding, intermediaries and reliance on third parties change impersonation and verification risk.
Transaction behaviour	20%	Actual use may confirm the expected profile or reveal a material change in risk.

Weighted score = customer score x 35% + geography score x 20% + product score x 15% + channel score x 10% + transaction score x 20%.

3 Scoring scale

Score	Meaning	General description
1	Low	Simple, transparent and consistent with low-risk indicators.
2	Moderately low	Limited risk factors that standard controls address.
3	Moderate	One or more material risk factors needing closer review.
4	High	Significant exposure requiring EDD and enhanced approval or monitoring.
5	Very high	Severe or multiple risks; normally outside appetite unless a narrow exception is approved.

4 Customer and ownership risk

Score	Illustrative indicators
1	Salaried UAE resident with transparent income, simple needs and no negative information.
2	Established professional or operating company with clear ownership and ordinary expected activity.
3	Cash-intensive business, non-resident customer, newly formed company, moderate adverse media or activity requiring more explanation.
4	PEP, complex ownership, trust or foundation, higher-risk sector, unexplained nominee role, significant adverse information or high-value activity.
5	Identity or ownership cannot be established; shell-bank features; serious credible crime concerns; prohibited or sanctioned relationship.

5 Geography risk

Geography is assessed across nationality, residence, incorporation, business operations, source of funds, counterparties and payment corridors. The highest relevant exposure may set the score where averaging would conceal material risk.

- FATF public statements and other credible assessments of AML/CFT/CPF controls.
- UN and UAE sanctions, terrorism and proliferation-financing exposure.
- Corruption, organised crime, conflict, tax crime, trafficking and fraud indicators.
- Quality of beneficial ownership, identity and law-enforcement cooperation.
- The customer's real economic link to the country and whether the route has a credible purpose.

6 Product and delivery channel risk

Area	Lower risk examples	Higher risk examples
Product	Salary account, domestic bill payments, low-value debit card.	High-value international transfers, rapid pass-through activity, third-party collections, new or untested service.
Channel	Verified customer using the Bank's controlled application and strong authentication.	Remote onboarding with weak evidence, introducer or intermediary, repeated device or identity anomalies, non-face-to-face corporate control changes.

7 Transaction behaviour risk

At onboarding, expected behaviour is scored from declared activity and known context. After activity begins, the Bank compares actual behaviour with that expectation. Relevant indicators include volume, value,

velocity, cash-equivalent activity, counterparties, countries, time of day, dormant-account reactivation, rapid movement of funds and links to other customers.

A transaction alert does not automatically increase the rating. The rating should increase when the investigation identifies a continuing or material risk. Repeated unexplained alerts, an STR or SAR filing, material profile deviation or a confirmed network concern normally triggers reassessment.

8 Risk classification and control outcome

Weighted score	Class	Minimum outcome
1.00 to 1.79	Low	Standard CDD, 36-month review, standard monitoring.
1.80 to 2.79	Standard	Standard CDD, 24-month review, risk-based monitoring.
2.80 to 3.69	High	EDD, Financial Crime Compliance approval, 12-month review, enhanced monitoring.
3.70 to 5.00	Very high	Normally decline or exit. Any exception requires MLRO and senior management approval, restrictions and a 6-month review.
Prohibited rule	Unacceptable	Decline, freeze or exit as legally appropriate regardless of score.

9 Mandatory floors and prohibitions

Indicator	Minimum classification or action
Foreign PEP or related customer	High; senior management approval, SoF and SoW, enhanced monitoring.
Domestic or international-organisation PEP with material risk	High, unless documented evidence supports a lower class and Compliance agrees.
Complex ownership without clear commercial purpose	High until understood; decline if beneficial ownership cannot be established.
FATF high-risk jurisdiction subject to a call for action	Very high and enhanced countermeasures; ordinarily decline unless lawful and expressly approved.
Serious credible adverse information involving financial crime	High or very high according to recency, credibility, severity and nexus.
Confirmed UAE or UN sanctions match	Prohibited; freeze or reject and report under Part 4.
Anonymous or false identity, shell bank or unlawful activity	Prohibited; decline or exit and consider reporting.

10 Overrides and approval rules

An override changes the model result because reliable information shows that the calculated class does not represent the actual risk. It must not be used to meet a sales target or clear a queue.

- The system or an analyst may raise a rating when new risk is identified. The reason and evidence must be recorded.
- A downward override requires Financial Crime Compliance approval. A downward override from very high requires the MLRO as well.
- No override may remove a legal prohibition, sanctions obligation or mandatory risk floor.
- Every override must state the original score, revised class, reason, approver, date, controls and expiry or review date.
- Compliance will review override volumes and outcomes quarterly for bias, inconsistency or control avoidance.

11 Model governance

The model owner will document data sources, logic, weightings, thresholds, mandatory rules and limitations. Changes require testing and approval before release. At least annually, the Bank will review score distribution, approval and override patterns, alert and STR outcomes, false negatives, customer exits, data quality and changes in the EWRA.

Independent validation will assess conceptual soundness, implementation, data lineage and outcomes at a frequency based on risk and after a material change. Identified limitations will be recorded with interim controls and due dates.

12 Worked examples

Example	Scores	Result and judgement
UAE salaried retail customer	Customer 1; geography 1; product 1; channel 2; behaviour 1	1.10 Low. Remote channel is controlled by strong verification and does not change the overall class.
UAE SME importing electronics	Customer 3; geography 3; product 3; channel 2; behaviour 3	2.85 High. EDD is required due to sector, cross-border activity and expected payment pattern.
Foreign PEP with transparent assets	Customer 4; geography 2; product 2; channel 2; behaviour 2	2.90 High. The PEP floor confirms High even though documentation is credible.
Opaque holding company	Customer 5; geography 4; product 3; channel 3; behaviour 3	4.10 Very high. Decline if ownership and purpose cannot be resolved.

PART 4

Sanctions and screening policy

Customer payment PEP and adverse media controls with a clear match process

1 Policy objective

The Bank will prevent funds, assets or services from being made available to a person or entity subject to applicable targeted financial sanctions. It will screen customers and payments, investigate potential matches promptly, freeze or suspend where required, report through the prescribed channel and retain a complete audit trail.

2 Sanctions lists and risk scope

The mandatory targeted financial sanctions scope includes the UAE Local Terrorist List and the UN Security Council Consolidated List, together with binding UAE directions. The Bank may also screen other lists, such as those issued by the United States, United Kingdom or European Union, where required by correspondent banks, contractual obligations or risk appetite. Those additional lists must be governed separately so staff do not confuse a commercial restriction with a UAE legal freeze.

PEP and adverse-media screening support CDD and risk assessment. They do not create a sanctions freeze unless the person is also designated or another legal restriction applies.

3 Governance

Owner	Responsibility
Board and senior management	Approve sanctions risk appetite and ensure resources and systems are adequate.
MLRO	Owns the policy, determines material escalation and oversees required reporting.
Sanctions team	Investigates matches, advises operations, maintains decision records and tracks list changes.
Customer and payment operations	Operate screening holds, collect identifiers and do not release an unresolved match.
Technology and data owners	Maintain list ingestion, data interfaces, access controls, audit logs and resilience.
Independent assurance	Tests design, data completeness, tuning, decisions and reporting.

4 Who and what must be screened

- Customers, prospective customers and former customers where retrospective review is required.
- Beneficial owners, controllers, directors, authorised signatories, trustees, settlors, protectors, beneficiaries and relevant connected parties.
- Originators, beneficiaries, ordering and beneficiary institutions, intermediaries and relevant free-text payment information.
- Vendors, employees and other parties where the Bank's risk assessment or law requires screening.

Screening data must include all available identifiers, not the name alone. Useful identifiers include date and place of birth, nationality, address, identity or registration number, aliases, transliterations, vessel or aircraft data, and ownership or control links.

5 Customer screening

Customer screening must occur before onboarding and before a new connected party gains control or authority. The active customer base must be rescreened whenever a mandatory list changes and on a scheduled basis that ensures prompt detection. Material changes to a customer's name, ownership, control, nationality or address must trigger rescreening.

The matching method must support common spelling variations, Arabic and Latin transliteration, aliases, initials, word order and typographical differences. Thresholds must be tested so that efficiency does not create an unreasonable risk of missed matches.

6 Payment screening

Incoming and outgoing cross-border payments must be screened before release. Domestic and internal transfers will be screened according to the sanctions risk assessment, but mandatory list obligations apply regardless of channel. Screening must cover structured fields and relevant unstructured fields and must not be bypassed by manual repair or straight-through processing.

- A payment on hold remains controlled until an authorised decision is recorded.
- Changing or stripping a name to avoid an alert is prohibited and must be escalated.
- Rejected, cancelled and attempted payments remain subject to investigation and reporting.
- System outages require an approved contingency that prevents unscreened release.

7 PEP and adverse media screening

PEP screening is performed at onboarding, periodically and when data or vendor information changes. Adverse-media screening must focus on credible information relevant to financial crime risk. A result should be assessed for source reliability, identity match, allegation or fact, seriousness, recency, outcome and connection to the proposed relationship.

An article or database label is not enough to reject a customer. The reviewer must identify what is known, what remains uncertain and how it affects risk. Serious, credible information may justify EDD, higher approval, restrictions, rejection, exit or an internal referral.

8 Potential match investigation

1. Place the customer, account opening or payment under the required hold or suspension. Do not contact the subject about the match.
2. Compare the alert with list identifiers and internal records, including ownership and control data.
3. Use reliable external sources where needed to distinguish the parties.
4. Classify the result as false positive, potential or partial match, or confirmed match.
5. Record the evidence, reasoning, reviewer and approval. Release only when authority is clear.

Outcome	Meaning	Action
False positive	Identifiers show the party is not the listed person or entity.	Document and release. A controlled false-positive rule may be used if periodically reviewed.

Outcome	Meaning	Action
Potential or partial match	The Bank cannot reasonably confirm or rule out the match.	Suspend the transaction, file the required PNMR through goAML within five business days and maintain the suspension pending direction.
Confirmed match	Identifiers establish that the party is listed, owned or controlled by a listed person, or acting for one.	Freeze without delay and without notice, prohibit funds or services, and file the required FFR through goAML within five business days.

9 Blocking freezing rejection and exit

A freeze preserves the funds or assets and prevents movement, conversion, access or use. It is not the same as rejecting a payment or closing an account. The Bank must follow the legal measure that applies to the particular list and must not return or transfer frozen assets without lawful authority.

For a confirmed UAE or UN match, the Bank will freeze applicable funds and other assets without delay and without prior notice, stop services that would make value available, reject a prospective customer where appropriate, and report through the required channel. The Bank will maintain the measure until the designation is removed or a competent authority authorises a change.

Exit decisions must be coordinated with the MLRO and Legal. An operational closure must never defeat a freeze or reveal a confidential report.

10 List management and change control

- Subscribe to official UAE notifications and maintain a documented source inventory.
- Record receipt time, ingestion time, successful deployment, customer rescreening and exception handling.
- Reconcile the source list to the screening platform and investigate missing or rejected records.
- Test changes to matching logic, transliteration, thresholds and data mapping before release.
- Maintain a controlled rollback and outage process that prevents unscreened activity.

11 Quality assurance testing and records

Quality assurance will sample false positives, potential matches, confirmed matches, payment releases and reports. Testing will cover data completeness, matching effectiveness, timeliness, decision quality, maker-checker controls and evidence. Independent validation will be performed at least annually or after a material system or list change.

The Bank will retain alerts, list versions, customer and payment data, research, decisions, approvals, reports, communications, system logs and evidence of freezes or releases for at least the legal retention period.

PART 5

Transaction monitoring and STR framework

How the Bank detects investigates decides reports and learns from suspicious activity

1 Monitoring objectives

Transaction monitoring helps the Bank identify activity that may involve money laundering, a predicate offence, terrorism financing, proliferation financing or another form of financial crime. Monitoring covers completed and attempted activity and combines automated scenarios, targeted reviews, employee referrals, screening intelligence, fraud information and requests from competent authorities.

All customers are subject to monitoring. The intensity, scenarios and prioritisation vary according to risk, but a low-risk rating does not remove monitoring.

2 Monitoring design

The monitoring programme must reflect the Bank's EWRA, products, customers, countries, channels, data and known typologies. Scenario design should state the risk addressed, data used, population covered, logic, thresholds, limitations and expected outcome.

Risk theme	Illustrative detection
Rapid movement	Funds received and transferred out quickly with little retained balance or economic explanation.
Structuring	Repeated transactions below an expected threshold or fragmented across accounts or days.
Profile deviation	Value, volume, countries, counterparties or products materially inconsistent with the customer profile.
Pass through or mule activity	Multiple third-party credits followed by rapid withdrawals, card spend or transfers.
High-risk geography	Unexpected or disproportionate activity involving higher-risk locations or corridors.
Corporate misuse	Payments inconsistent with stated business, circular flows, unrelated third parties or dormant company activity.
Terrorism or proliferation financing	Small or unusual transfers, sanctioned or controlled-goods nexus, front-company indicators or network links.

3 Data and system controls

The Bank must know which transactions and customer attributes feed the monitoring system. Data owners will reconcile source systems, transaction codes, customer identifiers, dates, values and currencies and will investigate missing, duplicated, delayed or incorrectly mapped records.

Monitoring changes must follow documented change control. Testing will cover expected alerts, non-alerts, boundary values, population coverage and audit logging. Access to rules, thresholds and alert decisions is restricted by role and subject to maker-checker control.

4 Alert prioritisation

Alerts will be risk-scored using factors such as customer risk, scenario severity, transaction value, geography, prior alerts, network links, PEP status and recent profile changes. Urgent matters are moved to expedited review. Queue age and high-risk backlogs must be visible to management.

- A sanctions or terrorism-financing concern, active law-enforcement request, suspected ongoing fraud, imminent dissipation of funds or clear evidence of crime requires immediate escalation.
- Alerts involving higher-risk customers or severe typologies receive priority over routine lower-risk alerts.
- Service-level targets are management controls, not permission to close an alert without adequate work.

5 Alert review and investigation

The reviewer must reconstruct what happened and decide whether the activity is reasonably explained. The file should allow another competent reviewer to follow the facts and reach an informed decision.

1. Confirm the alert logic, customer, accounts, period, transactions and linked parties.
2. Review current and historical CDD, risk rating, expected activity, prior alerts, cases, referrals and reports.
3. Analyse transaction flow, counterparties, countries, channels, values, timing, velocity and economic purpose.
4. Use internal links and reliable external information to understand the parties, business and relevant typology.
5. Request information only where it is necessary, safe and unlikely to create tipping-off risk.
6. State the red flags, supporting and mitigating information, gaps and conclusion.
7. Close with a clear rationale or escalate with a recommendation to file, restrict, review or exit.

A customer's explanation is evidence to assess, not a reason to close the case automatically. Documents must be checked for authenticity, relevance and consistency with the payment trail.

6 Escalation and investigation timing

Suspicion must be reported without delay. Internal service levels will be set below regulatory maximums and adjusted for urgency. In the absence of expedited review, the Bank will aim to complete the alert, investigation, recommendation and decision well before the CBUAE guidance maximum of 35 business days from automated alert generation.

Stage	Internal target	Control
Initial alert triage	5 business days	Prioritise urgent and higher-risk matters; identify missing data.
Standard investigation	20 business days from alert	Complete analysis and submit a clear recommendation.
MLRO decision and filing	As soon as reasonable and within the overall 30-business-day internal target	Maker-checker review for accuracy and completeness.
Expedited matter	MLRO decision within 24 hours of escalation; file within 24 hours of decision	Urgent access and documented reason.
Complex investigation	Initial report within 15 business days; follow-up within 30 business days after initial filing	Use only where genuinely complex; continue investigation.

These targets do not justify delay. If the available facts already support suspicion, the case must be escalated and reported without waiting for every question to be answered.

7 STR and SAR decision making

The MLRO or formally authorised deputy makes the final decision whether to file an STR, SAR or another report type. The threshold is reasonable grounds to suspect; proof of the underlying crime is not required. There is no minimum monetary threshold, and attempted transactions may be reportable.

Decision	Required record
File	Facts, grounds for suspicion, report type, urgency, linked parties, restrictions, filing date and goAML reference.
Do not file	Red flags considered, reliable explanation or evidence, remaining gaps, reviewer and approver.
Continue investigation	Why more work is necessary, interim risk controls, owner and firm deadline. This must not delay a report once suspicion exists.

Defensive reporting is not acceptable. The Bank should not file simply because information is missing when the available facts do not support suspicion. Equally, missing information is not a reason to avoid filing where the known facts do support suspicion.

8 Report preparation and filing

Reports will be submitted through goAML using the correct report type. The narrative should explain who was involved, what occurred, when and where it occurred, why it is suspicious and how the activity was carried out. It should distinguish facts from assumptions, quantify relevant activity and identify supporting documents.

- Use clear chronological writing and identify the customer's normal profile.
- Describe the key transactions and flow of funds rather than listing every entry.
- Explain the red flags, customer response, research and reason the explanation was inadequate.
- Check names, account numbers, dates, values, currencies and linked report references.
- Apply maker-checker review before submission, except where urgency requires immediate filing followed by documented quality review.

9 Action after filing

Filing does not by itself require account closure, nor does it authorise the Bank to freeze funds. The MLRO will decide whether to continue, restrict or exit the relationship, taking account of legal instructions, customer risk, ongoing exposure, monitorability and tipping-off risk.

A customer who remains with the Bank after a filing will receive enhanced monitoring and a risk review. Continuing suspicious activity must be assessed promptly for a further report. FIU requests and feedback must be handled through restricted channels and within the specified deadline.

10 Confidentiality and tipping off

Information about an internal referral, investigation, STR or SAR, FIU request or related law-enforcement interest is restricted to staff with a genuine need to know. No person may disclose to the customer or another unauthorised party that a report has been or may be filed, or that an investigation is under way, where the disclosure could prejudice the matter or breach law.

- Use neutral customer questions that seek normal CDD information without mentioning suspicion.
- Do not place STR or SAR references in customer-visible systems, correspondence or unrestricted notes.
- Do not discuss cases in open channels or with staff who are not involved.
- Escalate any accidental disclosure immediately to the MLRO, Legal and Information Security.

11 Quality assurance and programme testing

Quality control checks the accuracy of a decision before it is final. Quality assurance looks across completed work to identify patterns, training needs and control weaknesses. The Bank will use both.

Review	Minimum focus
Alert and case QA	Scope, transaction analysis, CDD use, red flags, evidence, rationale, timeliness and disposition.
STR or SAR QA	Threshold, report type, narrative, data accuracy, supporting documents, timeliness and confidentiality.
Scenario effectiveness	Coverage, productivity, false positives, missed risk, threshold performance and typology relevance.
Data validation	Completeness, accuracy, timeliness, reconciliation, rejected records and lineage.
Independent validation	Conceptual soundness, implementation, change control, outcomes and limitations.

Material QA failures will be corrected in the affected file and assessed for wider impact. The Bank will consider whether previously closed alerts, customer ratings or reports need review.

12 Management information and records

Management information must show more than volume. It should help management identify risk and act. Relevant measures include alert ageing, high-risk backlog, investigation outcome, report timeliness, scenario productivity, repeat alerts, staff capacity, QA error themes, data incidents, overdue remediation and continuing activity after filing.

Alert records, investigation files, research, decisions, reports, FIU correspondence, monitoring logic, test results and change approvals will be retained for at least the legal retention period and protected from unauthorised access.

PART 6

Short enterprise wide risk assessment

Illustrative assessment of inherent risk control effectiveness residual risk and priorities

1 Assessment scope and method

This short EWRA is an illustrative management assessment for the business assumptions in Part 1. It is not based on an operating bank's customer or transaction data. A real EWRA would use portfolio data, product volumes, country exposure, alert outcomes, losses, STRs, control testing, audit findings and external risk information.

Inherent risk is the exposure before controls. Control effectiveness is assessed as Effective, Generally effective, Needs improvement or Ineffective. Residual risk is the exposure remaining after controls. The Bank compares residual risk with its risk appetite and records actions where the risk is too high or uncertain.

2 Inherent and residual risk summary

Risk area	Inherent risk	Key controls	Control effectiveness	Residual risk
Retail customers	Medium	Digital identity, screening, risk rating, monitoring and device controls.	Generally effective	Medium-low
SME and legal entities	High	Ownership tracing, registry checks, EDD, expected activity and enhanced monitoring.	Needs improvement	Medium-high
Geography and cross-border payments	High	Country model, payment screening, corridor monitoring and restrictions.	Generally effective	Medium
Products	Medium-high	Product risk assessment, limits, scenario coverage and approval before launch.	Generally effective	Medium
Remote delivery channel	High	Document authentication, liveness, device intelligence and manual review.	Generally effective	Medium
Sanctions and PF	High	List updates, customer and payment screening, holds, reporting and annual validation.	Generally effective	Medium
Transaction monitoring and STR	High	Risk-based scenarios, prioritisation, investigation, MLRO decision and QA.	Needs improvement	Medium-high
Outsourcing and data	Medium-high	Due diligence, contracts, service monitoring, reconciliation and access controls.	Needs improvement	Medium-high

3 Overall assessment

Overall inherent ML/TF/PF and sanctions risk is High because the Bank onboards customers remotely, serves legal entities and supports international payments. The control environment is assessed as Generally effective with important improvement needs. Overall residual risk is Medium-high and is within appetite only if the remediation below is funded, tracked and completed on time.

The principal concentration is not ordinary retail banking. It is the combination of remote onboarding, SME ownership complexity, international payment corridors and limited operating history for monitoring models.

4 Key deficiencies

Deficiency	Risk effect	Interim control
Corporate ownership data is partly held in unstructured documents.	Changes and linked owners may not be detected consistently.	Manual ownership checklist and second review for High-risk entities.
Transaction monitoring has limited historical outcome data.	Thresholds may generate excess alerts or miss emerging patterns.	Conservative thresholds, monthly outcomes analysis and targeted reviews.
Third-party adverse-media results require manual deduplication and source review.	Backlogs may delay onboarding or periodic review.	Risk-prioritised queues and daily ageing oversight.
Evidence of sanctions list deployment is stored across several systems.	It may be difficult to prove complete and timely rescreening.	Daily reconciliation and a central evidence register.
Data lineage from payment platforms to monitoring is not yet fully automated.	Missing or misclassified transactions may not be detected promptly.	Daily control totals and exception investigation.

5 Remediation priorities

Priority and timing	Action	Owner	Success measure
1 Within 90 days	Create a structured legal-entity and ownership data model and migrate active High-risk files.	Head of Onboarding and Data	At least 98% of required ownership fields complete; exceptions approved.
2 Within 90 days	Implement one sanctions list-deployment register with automated reconciliation and evidence retention.	Sanctions and Technology	Every update has receipt, deployment, rescreening and exception evidence.
3 Within 180 days	Complete end-to-end transaction data lineage and automate daily control totals.	Data Owner	All in-scope feeds reconciled; unresolved breaks remain below approved tolerance.
4 Within 180 days	Tune high-volume scenarios using outcomes and typology coverage without weakening High-risk detection.	TM Model Owner	Documented productivity improvement and no unexplained coverage gap.
5 Within 12 months	Commission independent validation of customer risk rating, screening and transaction monitoring.	Chief Compliance Officer	All high findings have approved actions and dates.

6 Governance and acceptance

The MLRO will report progress monthly to the Executive Management Committee and quarterly to the Board Risk and Compliance Committee. Overdue Priority 1 or 2 actions, material control failures or risk above appetite require immediate escalation and a decision to restrict activity, add resources or suspend the affected product. The EWRA is refreshed annually and after a material change.

Appendix A Decision and escalation authority

Decision	Prepare	Approve	Consult or notify
Standard customer	Onboarding analyst	Onboarding manager	Automated or sampled Compliance oversight
High-risk customer	Senior analyst	Financial Crime Compliance	Business owner
Foreign PEP or Very-high exception	Senior analyst and Compliance	Senior management with MLRO opinion	Business owner
Downward risk override	Model user	Financial Crime Compliance; MLRO if from Very high	Model owner
Confirmed sanctions match	Sanctions investigator	MLRO or authorised sanctions officer for reporting	EOCN and CBUAE through prescribed channel
STR or SAR	Investigator	MLRO or authorised deputy	UAE FIU through goAML
Customer exit for financial crime	Business and investigations	MLRO plus authorised business executive	Legal and Operations
Policy exception	Control owner	MLRO and accountable executive	Operational Risk; Board committee if material

Appendix B CDD information and evidence

Customer	Minimum information	Common verification evidence
Individual	Legal name, other names, date and place of birth, nationality, identity number, address, contact, tax residence, occupation, purpose and expected activity.	Passport, Emirates ID or other accepted government ID; trusted digital identity; address and employment evidence where required.
Sole proprietor	Individual data plus trading name, licence, business activity, operating address, turnover, counterparties and expected transactions.	Identity evidence, trade licence, registry extract, invoices, contracts, tax or financial records.
Company	Legal and trading names, form, registration, addresses, business, tax residence, directors, signatories, ownership and control, purpose and expected activity.	Licence, certificate of incorporation, constitutional documents, registry data, ownership chart, resolutions, financial statements and operating evidence.
Partnership	Partners, managing partners, ownership, authority, business and expected activity.	Partnership agreement, registration, licences, resolutions and identity evidence.
Trust or arrangement	Settlor, trustee, protector, beneficiaries or class, controllers, purpose, assets and expected activity.	Trust deed or equivalent, appointment documents, legal opinion where needed and identity or ownership evidence.
Non-profit organisation	Purpose, registration, governance, controllers, donors, beneficiaries, countries, fundraising and disbursement model.	Registration, constitution, board records, programme evidence, accounts, donor and beneficiary controls.

Appendix C Glossary

Term	Plain language meaning
AML	Anti-money laundering.

Term	Plain language meaning
Beneficial owner or UBO	The natural person who ultimately owns or controls a customer or on whose behalf a transaction is conducted.
CDD	Customer due diligence.
CFT	Combating the financing of terrorism.
CPF	Countering proliferation financing.
EOCN	Executive Office for Control and Non-Proliferation.
EDD	Enhanced due diligence.
EWRA	Enterprise-wide risk assessment.
FIU	United Arab Emirates Financial Intelligence Unit.
LFI	Licensed financial institution.
MLRO	Money Laundering Reporting Officer.
PEP	Politically exposed person, including relevant family members and close associates as defined by applicable requirements.
PF	Proliferation financing.
PNMR	Partial Name Match Report submitted through goAML for an unresolved potential sanctions match.
RBA	Risk-based approach.
SAR	Suspicious Activity Report.
SoF	Source of funds used for a relationship or transaction.
SoW	Source of the customer's overall wealth.
STR	Suspicious Transaction Report.
TFS	Targeted financial sanctions.

Appendix D Regulatory reference framework

The following official sources informed this portfolio edition. They were checked on 22 September 2026. Current law, regulatory directions and official list updates must always be checked before operational use.

- Federal Decree-Law No. 10 of 2025 regarding Anti-Money Laundering and Combating the Financing of Terrorism and Proliferation Financing [Official source](#)
- Cabinet Resolution No. 134 of 2025 regarding the Executive Regulations of Federal Decree-Law No. 10 of 2025 [Official source](#)
- Cabinet Decision No. 74 of 2020 concerning the UAE Local Terrorist List and implementation of relevant UN Security Council decisions [Official source](#)
- CBUAE AML and CFT Rulebook collection [Official source](#)
- CBUAE Guidance for Licensed Financial Institutions on CDD KYC and record keeping [Official source](#)
- CBUAE Guidance on transaction monitoring and sanctions screening [Official source](#)
- CBUAE Guidance on suspicious transaction reporting [Official source](#)
- EOCN UAE and UN sanctions lists and targeted financial sanctions material [Official source](#)
- FATF Recommendations as amended June 2026 [Official source](#)

Document end

Questions about this manual, its interpretation or a proposed exception must be sent to the MLRO. Urgent sanctions, suspicion or tipping-off concerns must be escalated immediately through the restricted Financial Crime Compliance channel.